

SIMATS ENGINEERING ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

Total

Marks:100

Annexure A **VULNERABILITY ASSESSMENT REPORT**

Code of Conduct:

*I **Lekkala Dattu Kumar (19232141)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: L Dattu Kumar

VULNERABILITY ASSESSMENT REPORT – ANSWERS

Course: Ethical Hacking (ITA1410) | CO4: Network Security Testing and Wireless Security

Note: The following answers address all five case-study questions given in Annexure A. The assessment's front page is retained unchanged in the final PDF.

1. TJX Companies Wireless Network Breach, 2005–2007

Incident Background and Technical Understanding

TJX Companies suffered a major payment-card data breach after attackers gained unauthorized access through the retailer's wireless network. The case information states that TJX was using WEP while transitioning to WPA and lacked adequate controls to restrict wireless access. The incident illustrates how obsolete wireless encryption, weak access control, poor monitoring and insufficient network segmentation can turn a wireless entry point into a path toward sensitive payment systems.

Wireless Vulnerabilities Identified

Encryption: WEP is obsolete and vulnerable to key-recovery attacks; WPA transition controls were insufficient.

Authentication: Strong enterprise authentication and individual credentials were not adequately enforced.

Wireless access: Wireless users were not sufficiently restricted from sensitive internal resources. **Segmentation:** Payment-card environments were insufficiently isolated from less-trusted wireless networks. **Monitoring:** Wireless intrusion/rogue-device monitoring was inadequate, reducing the chance of early detection.

Data protection: Sensitive payment information required stronger encryption, access control and PCI DSS-aligned protection.

Risk, Impact and Root Cause

The primary attack vector was unauthorized wireless access followed by movement toward systems handling payment data. Root causes included obsolete encryption, weak wireless access restrictions, inadequate segmentation and insufficient monitoring. The impact could include theft of payment-card data, financial losses, incident-response costs, regulatory penalties, customer notification, loss of trust and reputational damage. The likelihood is **High** when obsolete wireless security is combined with poor internal isolation; the overall risk is **Critical** for a payment-card environment.

Security Recommendations and Mitigation

1. Replace WEP with **WPA2-Enterprise or WPA3-Enterprise** using strong authentication.
2. Use 802.1X/RADIUS with unique user or device credentials and certificate-based authentication where appropriate.
3. Separate guest, corporate and payment-card networks using VLANs, firewalls and least-privilege rules.
4. Deploy wireless IDS/IPS and rogue-access-point detection.
5. Encrypt payment data in transit and at rest and strictly limit access to the cardholder-data environment.
6. Apply PCI DSS controls, regular vulnerability assessments, logging, monitoring and incident-response procedures.
7. Conduct security awareness training and periodic wireless configuration reviews.

Risk Rating Summary

Wireless encryption: **Critical**; authentication/access control: **High**; segmentation: **Critical**; monitoring: **High**; payment-data protection: **Critical**. Overall: **Critical**.

2. Lowe's Wireless Network Intrusion, 2003

Incident Background and Technical Understanding

In 2003, attackers compromised the wireless network of a Lowe's store in Southfield, Michigan. According to the case, the wireless connection provided a path to central systems and other retail locations, and the attackers attempted to install software intended to capture customers' credit-card information. The central security failure was allowing a local wireless compromise to provide excessive access to a nationwide corporate environment.

Wireless Vulnerabilities Identified

Authentication: Wireless access controls were not strong enough to prevent unauthorized association.

Wireless isolation: The compromised store network was not sufficiently isolated from critical corporate systems. **Firewall**

controls: Network boundaries did not adequately restrict traffic from a potentially hostile wireless segment. **POS**

segmentation: Point-of-sale systems and sensitive payment systems needed stronger logical separation.

Intrusion detection: Monitoring should have identified unusual wireless and internal activity earlier. **Centralized**

access management: Access privileges were not sufficiently limited according to location, device, identity and business need.

Risk, Impact and Root Cause

The attack vector was a local wireless compromise followed by lateral movement into corporate resources. The root cause was excessive trust between wireless, store, corporate and payment-related networks. Potential impacts include credit-card theft, malware deployment, disruption of retail operations, financial loss, regulatory exposure and reputational damage. Likelihood is **High** where wireless networks can directly reach sensitive internal systems; overall risk is **Critical**.

Security Recommendations and Mitigation

1. Use WPA2-Enterprise/WPA3-Enterprise with 802.1X and centralized RADIUS authentication.
2. Place wireless clients in dedicated VLANs with deny-by-default firewall rules.
3. Fully segment POS/cardholder systems from employee and wireless networks.
4. Permit only required application flows between stores and central systems.
5. Deploy IDS/IPS, wireless monitoring and centralized SIEM logging.
6. Apply role-based and least-privilege access management with rapid credential revocation.
7. Conduct regular penetration testing, vulnerability scanning and incident-response exercises.

Risk Rating Summary

Wireless authentication: **High**; network isolation: **Critical**; firewall/POS segmentation: **Critical**; intrusion detection: **High**; centralized access management: **High**. Overall: **Critical**.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

Incident Background and Technical Understanding

Firesheep demonstrated that an attacker on the same open wireless network could capture unencrypted session cookies and impersonate an authenticated user. The case highlights the weakness of protecting only the login page while allowing later application traffic and session information to travel without full HTTPS protection.

Wireless and Web Vulnerabilities Identified

Open Wi-Fi: Users on an open network could observe traffic from other clients.

Session cookies: Cookies transmitted without adequate protection could be stolen and reused. **HTTPS:**

Login-only encryption was insufficient; entire authenticated sessions needed HTTPS. **HSTS:** Without HSTS, users could be more exposed to downgrade or insecure HTTP requests.

Client isolation: Wireless clients should not be able to directly communicate with one another where unnecessary.

User awareness: Users needed guidance about untrusted Wi-Fi and secure browsing/VPN use.

Risk, Impact and Root Cause

The attack vector was passive or semi-passive traffic observation on a shared wireless network followed by session-cookie reuse. The root cause was inadequate end-to-end protection of authenticated web sessions. Impacts include account takeover, unauthorized transactions, privacy loss and reputational damage. Likelihood is **High** on open or poorly protected public Wi-Fi when applications fail to enforce secure sessions; overall risk is **High**.

Security Recommendations and Mitigation

1. Enforce HTTPS across the entire website, not only the login page.
2. Enable HSTS and use secure TLS configurations.
3. Mark authentication/session cookies **Secure**, **HttpOnly** and appropriately **SameSite**.
4. Rotate session identifiers after authentication and invalidate sessions on logout or suspicious activity.
5. Enable wireless client isolation on public access points.
6. Encourage or provide VPN protection for users on untrusted networks.
7. Use MFA for sensitive accounts and train users not to trust unexpected captive-portal or certificate warnings.

Risk Rating Summary

Open-network exposure: **High**; session-cookie protection: **Critical**; HTTPS/HSTS: **Critical**; client isolation: **Medium–High**; user awareness: **Medium**. Overall: **High**.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

Incident Background and Technical Understanding

The DarkHotel campaign targeted selected business executives and government officials through compromised hotel networks. Guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The case demonstrates the danger of third-party Wi-Fi administration, compromised captive portals, insecure update mechanisms and insufficient monitoring.

Wireless Vulnerabilities Identified

Guest authentication: Hotel authentication must prevent unauthorized access and protect credentials.

Captive portal: Portal integrity and TLS protection are essential because a compromised portal can be used for phishing or malware delivery.

DNS integrity: DNS manipulation can redirect users to malicious destinations or fake update pages.

Segmentation: Guest devices must be isolated from hotel operational and management networks. **Third-party access:** Vendors and administrators need controlled, logged and least-privilege access.

Software updates: Updates must be obtained through trusted channels and verified using digital signatures.

Monitoring: Privileged systems and guest-network activity require centralized logging and anomaly detection.

Risk, Impact and Root Cause

The attack chain can be summarized as: hotel network compromise → targeted guest connection → fraudulent update prompt → malware installation → compromise of the executive's device. Root causes include excessive trust in third-party infrastructure, weak portal/DNS controls, inadequate segmentation and insufficient endpoint/update verification. Impacts include credential theft, espionage, data loss and severe reputational damage. Overall risk is **Critical** for high-value guests.

Security Recommendations and Mitigation

1. Use WPA2/WPA3-Enterprise where appropriate for staff and separate secure guest access for visitors.
2. Harden captive portals with HTTPS, secure certificates, strong authentication and anti-phishing controls.
3. Protect DNS using trusted resolvers, DNS security controls and monitoring for unexpected changes.
4. Isolate guest devices from hotel POS, surveillance, building-management and administrative networks.
5. Restrict vendor/third-party access through MFA, VPN, jump hosts and least privilege.
6. Require signed software updates and verify digital signatures before installation.
7. Deploy endpoint protection, malware detection, wireless monitoring and centralized SIEM alerts.
8. Maintain incident-response procedures for targeted attacks against privileged guests and systems.

Risk Rating Summary

Captive portal/DNS: **High**; segmentation: **Critical**; third-party access: **High**; update integrity: **Critical**; monitoring: **High**. Overall: **Critical**.

5. Marriott Wi-Fi Deauthentication Incident, 2014

Incident Background and Technical Understanding

The case describes an FCC investigation involving Marriott equipment used to send Wi-Fi deauthentication messages that prevented guests from using personal hotspots. Marriott agreed to a \$600,000 civil penalty. The incident demonstrates how IEEE 802.11 management frames, when insufficiently protected, can be abused to disconnect legitimate wireless users and affect network availability.

Wireless Vulnerabilities Identified

Deauthentication frames: Traditional 802.11 management frames could be spoofed or misused to force clients off a network.

Availability: Repeated deauthentication can create denial-of-service conditions for legitimate users.

Management-frame protection: Lack of adequate protection made management traffic more susceptible to abuse.

Wireless interference: Deliberate disruption can affect guest connectivity and business operations.

Monitoring: Wireless intrusion detection should identify abnormal deauthentication patterns.

Policy: Acceptable-use rules must clearly define permitted wireless security controls and prohibit disruptive practices unless specifically authorized.

Risk, Impact and Root Cause

The attack/abuse vector is the transmission or spoofing of deauthentication frames to terminate legitimate client associations. The primary impact is loss of availability, which can affect guest communications, business services and customer experience. Root causes include inadequate protection of management frames, insufficient monitoring and inappropriate use of wireless control mechanisms. Likelihood depends on the wireless environment, but impact can be **High**; overall risk is **High** where such activity is possible and not detected.

Security Recommendations and Mitigation

1. Use modern Wi-Fi security with **Protected Management Frames (PMF/802.11w)** where supported.
2. Deploy **WPA3** configurations that require appropriate management-frame protection for protected networks.
3. Use wireless IDS/IPS to detect abnormal deauthentication/disassociation activity and identify the source.
4. Maintain centralized logs and incident-response procedures for availability attacks.
5. Establish acceptable-use policies that prohibit unauthorized disruption, jamming or forced disconnection of legitimate users.
6. Regularly assess access points, controllers and firmware for secure configurations and updates.
7. Ensure wireless security practices comply with applicable laws, regulations, contracts and consumer-protection requirements.

Risk Rating Summary

Deauthentication abuse: **High**; availability impact: **High**; management-frame protection: **High**; monitoring: **High**; policy/legal exposure: **High**. Overall: **High**.

Overall Conclusion

Across all five incidents, the recurring security lessons are to replace obsolete wireless security, " "use strong enterprise authentication, isolate wireless clients and sensitive systems, continuously monitor " "for rogue devices and abnormal activity, protect sensitive data end-to-end, verify software and DNS integrity, " "and maintain clear security policies with incident-response procedures. The appropriate controls should be " "selected according to the threat model and the sensitivity of the affected assets.

Risk Rating Summary

Case	Overall Risk	Primary Weakness
TJX	Critical	WEP, weak access control, segmentation and payment-data protection
Lowe's	Critical	Wireless-to-corporate access and inadequate POS isolation
Firesheep	High	Unencrypted sessions and insecure public Wi-Fi
DarkHotel	Critical	Compromised hotel infrastructure and malicious update delivery
Marriott	High	Deauthentication abuse and management-frame protection